

RPA skalieren ohne Kontrollverlust

Governance, Audit Trail, Exceptions, Security by Design –
und Change Management als Verantwortungsarchitektur.

Lehrskript – Tag 12 von 16

Lernpfad:
Wissen → Anwendung → Management

Bearbeitungsdauer:
1 Kurstag

Dozent:
Can Siebert

Format:
Theorie · Fallstudie · Coaching

Lernziele dieses Tages

Tag 11 hat gezeigt, dass RPA als Steuerungshebel verstanden werden muss. Heute geht es darum, ein wachsendes RPA-Portfolio *auditfähig und sicher zu skalieren*: Governance leicht, aber verbindlich, Audit Trail als Standard, Exception Handling als Disziplin, Security by Design als Pflicht und Change Management als Teil des Designs – nicht als Nachtrag.

L1 – Wissen (Reproduktion und Einordnung)

- Bot-Lifecycle und Governance-Bausteine kennen: Idea → Assessment → Design → Build → Test → Deploy → Run → Improve → Retire.
- Rollen und Rollenträger im RPA-Operating-Modell unterscheiden (Process Owner, Bot Owner, Developer, Reviewer, Security, Operations, Change).
- Audit-Trail-Anforderungen verstehen: Traceability, Aufbewahrung, Access-Kontrolle, Beweisführung.
- Exception-Klassen (Business, System, Data, Security) und Security-by-Design-Prinzipien (Least Privilege, SoD, Vault) einordnen.

L2 – Anwendung (Transfer auf konkrete Situationen)

- Ein “Minimum Viable Governance”-Modell entwerfen (Rollen, Lifecycle, Freigaben, Standards).
- Audit-Trail-Standard inkl. Aufbewahrung und Access-Regeln festlegen.
- Exception-Codes und 5 Exception-Playbooks (Eskalation, Owner, SLA) ableiten.
- Security-Guardrails (Account-/Credential-Konzept, SoD, Logging-Integrität) anwenden.

L3 – Management (Entscheidung und Verantwortung)

- Risk Appetite definieren und Bots in Low/Medium/High Risk klassifizieren.
- CoE vs. Föderation als bewusste Entscheidung treffen, mit Frühwarnsignalen.
- Fast-Track-Grenzen und Stop-Conditions verankern.
- Change Management von Beginn an im Operating Model verankern (Akzeptanz, Rollenwandel, Kommunikation).

Roter Faden

RPA skaliert dort, wo Governance *leicht* und Disziplin *konsequent* ist. Hundert Bots ohne Audit Trail sind ein Compliance-Albtraum – hundert Bots mit überreguliertem Prozess sind ein Innovationsfriedhof. Senior-Verantwortung heißt: das Gleichgewicht aus Geschwindigkeit und Nachweisbarkeit explizit zu entscheiden, nicht zu hoffen, dass es entsteht. (vgl. ISACA, 2018; Smeets et al., 2019)

1. Einstieg: Warum Skalierung neue Probleme erzeugt

Wer in einem Pilot fünf Bots betreibt, kennt jeden mit Namen. Wer in der Skalierung 80 Bots betreibt, kennt nur noch die, die ärgerlich sind. Diese qualitative Veränderung ist der eigentliche Skalierungssprung – nicht die Anzahl. Mit jeder Vervielfachung der Bots wachsen drei Klassen von Risiken nicht linear, sondern überproportional: Governance, Audit und Security.

1.1 Drei typische Skalierungs-Pathologien

1. **Wildwuchs.** Jeder baut, wie er will. Naming-Konventionen variieren, Logging ist unterschiedlich, Exception-Codes existieren in zehn Varianten. Eine zentrale Auswertung wird unmöglich.
2. **Compliance-Schock.** Der Auditor entdeckt im Audit-Sampling Bots ohne Logging, ohne Versionierung, mit shared Credentials. Folge: Stoppanordnung, Sonderprüfung, Reputationsschaden.
3. **Operationaler Stillstand.** Ein Portal-Update legt 15 Bots gleichzeitig lahm, niemand weiß, welche prioritär sind, alle Owner werden gleichzeitig kontaktiert. Reibung, Eskalationen, Vertrauensverlust.

1.2 Was Governance leisten muss

Governance ist nicht “Bürokratie für Auditoren”, sondern eine Sammlung von Mechanismen, die Skalierung möglich machen: (ISACA, 2018)

- **Vergleichbarkeit.** Bots werden so gebaut, dass sie sich vergleichen lassen (Naming, Logging, Versionierung).
- **Auffindbarkeit.** Wer welchen Bot wann gebaut hat, ist im zentralen Inventar nachvollziehbar.
- **Steuerbarkeit.** Bots können kontrolliert pausiert, neu deployed, abgeschaltet werden – ohne dass es von der Erinnerung einzelner Personen abhängt.
- **Lernfähigkeit.** Aus Incidents und Findings entstehen Verbesserungen des Standards – nicht nur Reparaturen einzelner Bots.

Eselsbrücke: V-A-S-L

Was eine Governance für skalierendes RPA leisten muss:

Vergleichbarkeit (einheitliche Standards)

Auffindbarkeit (zentrales Inventar)

Steuerbarkeit (kontrollierte Lifecycle-Operationen)

Lernfähigkeit (Standards entwickeln sich weiter)

Wer V-A-S-L verfehlt, hat keine Governance – nur Dokumente.

2. Bot-Lifecycle: vom Vorschlag bis zum Retirement

Jeder Bot durchläuft idealerweise einen klar definierten Lifecycle. Wer den Lifecycle überspringt oder verkürzt, holt sich später Probleme in Geschwindigkeit, Qualität oder Compliance.

(Smeets et al., 2019, Kap. 4)

2.1 Die neun Phasen

1. **Idea.** Eine Idee aus dem Fachbereich. Noch ungeprüft.